

CO2-AT2

ITA1407 - Ethical Hacking

PRANOV RAAJ G
192372355

Question 1

As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain tesla.com using theHarvester in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyze how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks.

Kali Linux Commands:

```
theHarvester --version
theHarvester -d tesla.com -b all
```

Command Explanation:

- **theHarvester --version** : Displays the installed theHarvester version (4.10.1) and confirms the tool is ready to run before starting the scan.
- **theHarvester -d tesla.com -b all** : Runs theHarvester against the domain tesla.com using every supported public OSINT source (search engines, certificate-transparency logs, DNS/passive-DNS databases, threat-intelligence feeds, code repositories, breach-lookup services, etc.) in a single pass. The tool only queries third-party public data sources — it never sends traffic directly to Tesla's infrastructure — so the entire scan remains passive reconnaissance.

Output Screenshots:

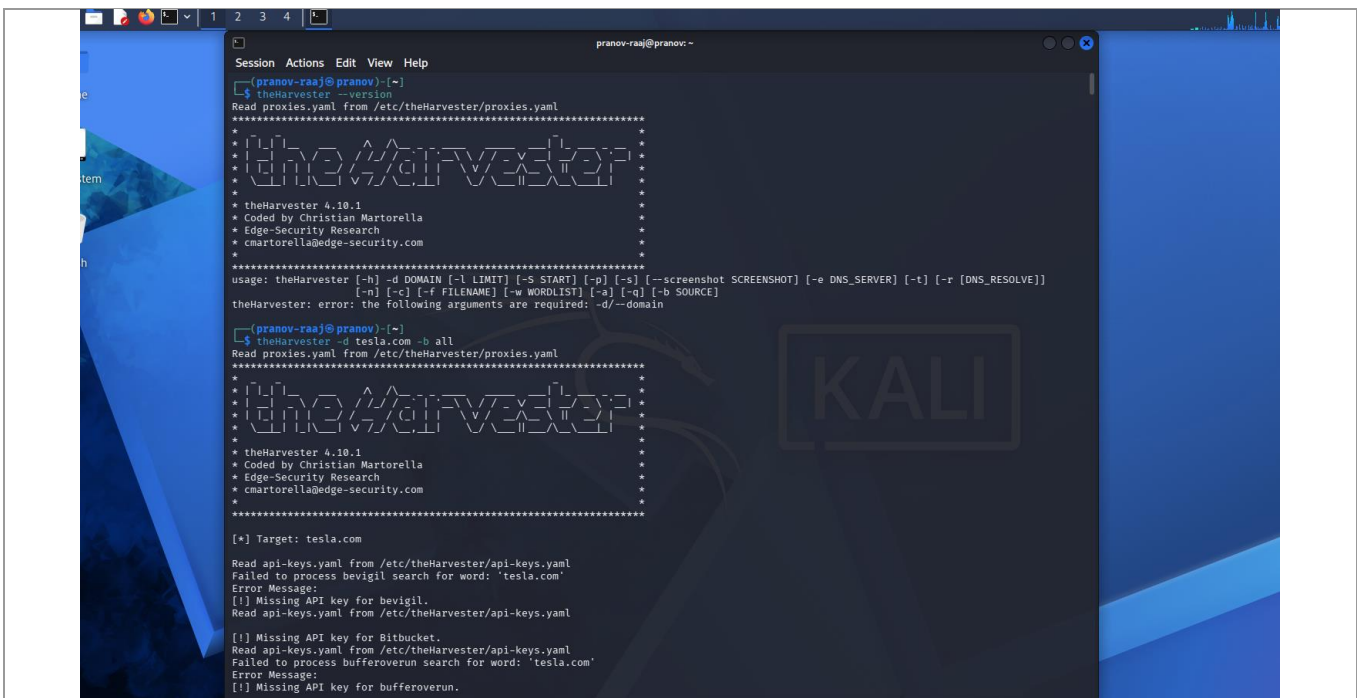
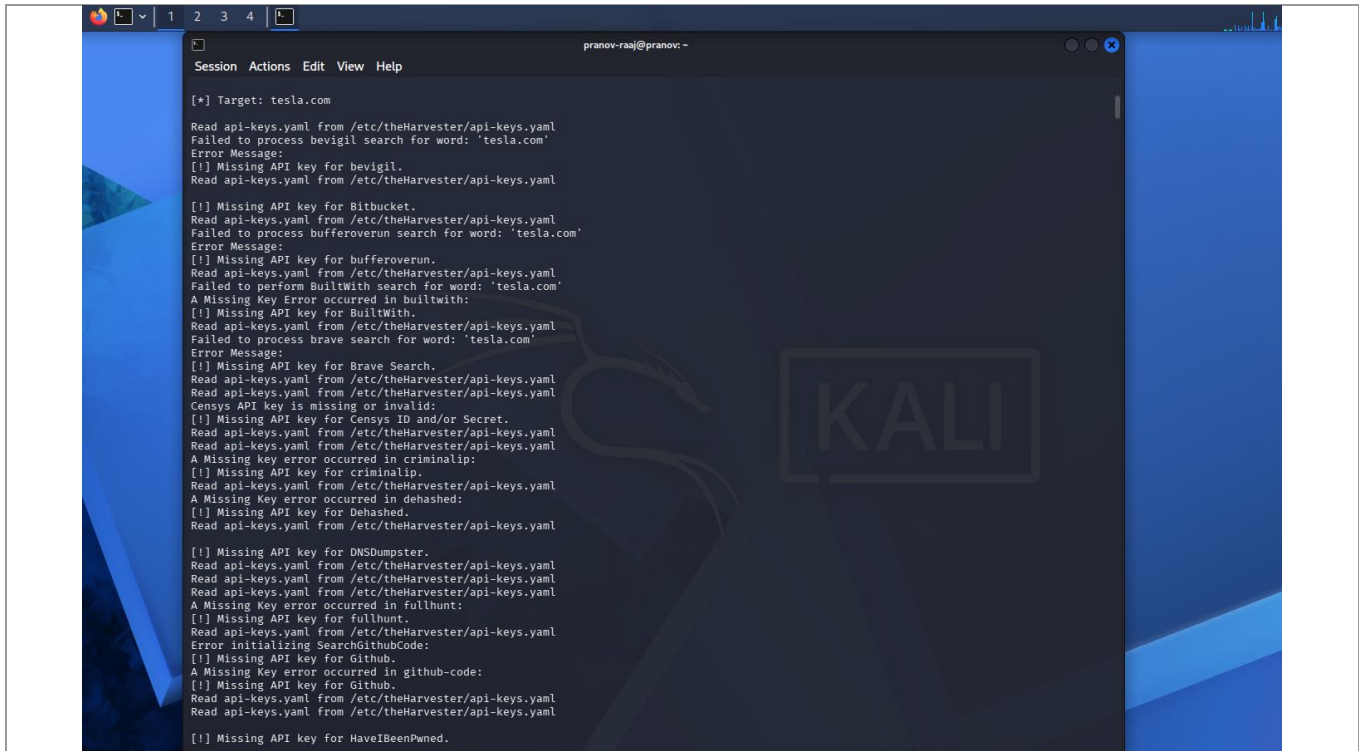
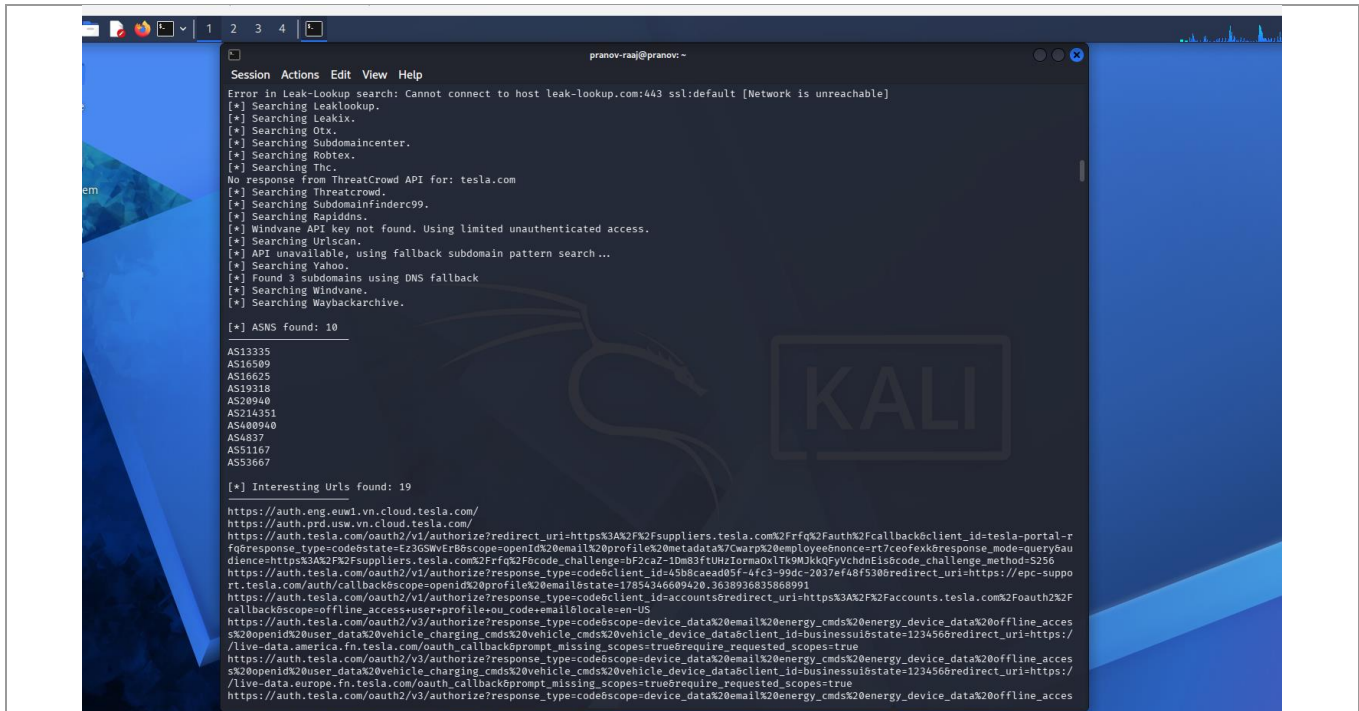


Fig 1.1 — theHarvester version check and scan launched with 'theHarvester -d tesla.com -b all'



```
pranov-raaj@pranov: ~  
Session Actions Edit View Help  
[*] Target: tesla.com  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
Failed to process bevigil search for word: 'tesla.com'  
Error Message:  
[!] Missing API key for bevigil.  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
[!] Missing API key for Bitbucket.  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
Failed to process bufferoverrun search for word: 'tesla.com'  
Error Message:  
[!] Missing API key for bufferoverrun.  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
Failed to perform BuiltWith search for word: 'tesla.com'  
A Missing Key Error occurred in builtwith:  
[!] Missing API key for BuiltWith.  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
Failed to process brave search for word: 'tesla.com'  
Error Message:  
[!] Missing API key for Brave Search.  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
Censys API key is missing or invalid:  
[!] Missing API key for Censys ID and/or Secret.  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
A Missing key error occurred in criminalip:  
[!] Missing API key for criminalip.  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
A Missing Key error occurred in dehashed:  
[!] Missing API key for Dehashed.  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
[!] Missing API key for DNSDumpster.  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
A Missing Key error occurred in fullhunt:  
[!] Missing API key for fullhunt.  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
Error Initializing SearchithubCode:  
[!] Missing API key for Github.  
A Missing Key error occurred in github-code:  
[!] Missing API key for Github.  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
[!] Missing API key for HaveIBeenPwned.
```

Fig 1.2 — Several premium sources (bevigil, Bitbucket, bufferoverrun, BuiltWith, Brave Search, Censys, criminalip, Dehashed, DNSDumpster, fullhunt, Github, HaveIBeenPwned) return 'Missing API key', so the scan continues with the sources that need no key.



```
pranov-raaj@pranov: ~  
Session Actions Edit View Help  
Error in Leak-Lookup search: Cannot connect to host leak-lookup.com:443 ssl:default [Network is unreachable]  
[*] Searching Leaklookup.  
[*] Searching Leakix.  
[*] Searching Otx.  
[*] Searching Subdomaincenter.  
[*] Searching Rottex.  
[*] Searching Thc.  
No response from ThreatCrowd API for: tesla.com  
[*] Searching Threatcrowd.  
[*] Searching Subdomainfinder99.  
[*] Searching Rapiddns.  
[*] Windvane API key not found. Using limited unauthenticated access.  
[*] Searching Urlscan.  
[*] API unavailable, using fallback subdomain pattern search...  
[*] Searching Yahoo.  
[*] Found 3 subdomains using DNS fallback  
[*] Searching Windvane.  
[*] Searching Waybackarchive.  
[*] ASNs found: 10  
AS12335  
AS16509  
AS16625  
AS19318  
AS20940  
AS214351  
AS400940  
AS4837  
AS51167  
AS53667  
[*] Interesting Urls found: 19  
https://auth.eng.euw1.vn.cloud.tesla.com/  
https://auth.pri.usx.vn.cloud.tesla.com/  
https://auth.tesla.com/oauth2/v1/authorize?redirect_uri=https%3A%2F%2Fsuppliers.tesla.com%2Fauth%2Fcallback&client_id=tesla-portal-r...  
fbqresponse_type=code&state=E23GSWVrB0scope=openId&20email%20profile%20metadatas%20employee&nonce=rtceofexk&response_mode=query&au...  
https://auth.tesla.com/oauth2/v1/authorize?response_type=code&client_id=453bcaead03f-4fc3-99dc-2037ef48f530&redirect_uri=https://epc-suppo...  
rt.tesla.com/auth/callback&scope=openId&20profile%20email%20state=17854346609420.3638936835868991  
https://auth.tesla.com/oauth2/v1/authorize?response_type=code&client_id=accounts&redirect_uri=https%3A%2F%2Faccounts.tesla.com%2Fauth%2F...  
callback&scope=offline_access&user-profile=ou_code=email@local=en-US  
https://auth.tesla.com/oauth2/v3/authorize?response_type=code&scope=device_data%20email%20energy_cmds%20energy_device_data%20offline_acces...  
s%20openId%20user_data%20vehicle_charging_cmds%20vehicle_cmds%20vehicle_device_data&client_id=businessui&state=i23456&redirect_uri=https://...  
/live-data.america.fn.tesla.com/oauth_callback&prompt_missing_scopes=true&require_requested_scopes=true  
https://auth.tesla.com/oauth2/v3/authorize?response_type=code&scope=device_data%20email%20energy_cmds%20energy_device_data%20offline_acces...  
s%20openId%20user_data%20vehicle_charging_cmds%20vehicle_cmds%20vehicle_device_data&client_id=businessui&state=i23456&redirect_uri=https://...  
/live-data.europe.fn.tesla.com/oauth_callback&prompt_missing_scopes=true&require_requested_scopes=true  
https://auth.tesla.com/oauth2/v3/authorize?response_type=code&scope=device_data%20email%20energy_cmds%20energy_device_data%20offline_acces...
```

Fig 1.3 — 10 ASNs and 19 interesting URLs (OAuth/SSO authorize endpoints) discovered.

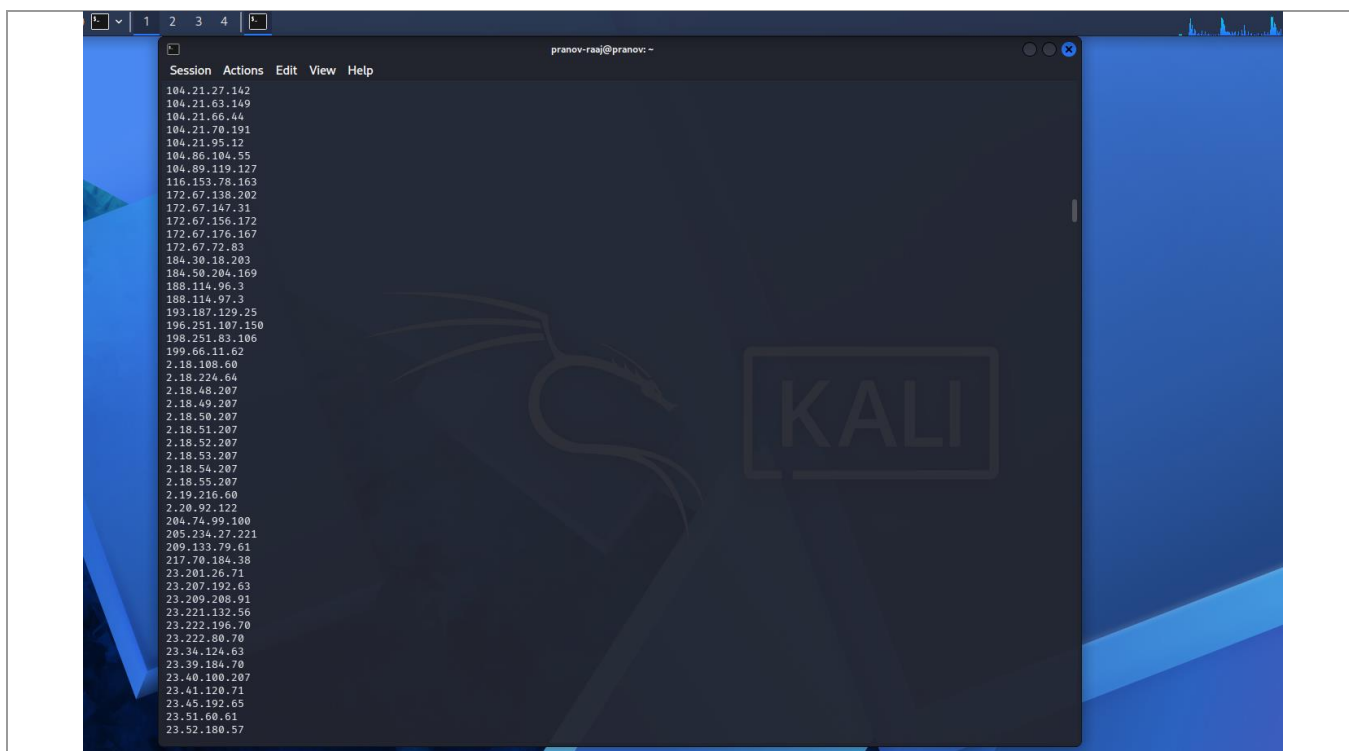


Fig 1.4 — IP addresses associated with tesla.com resolved from public DNS/passive-DNS sources.

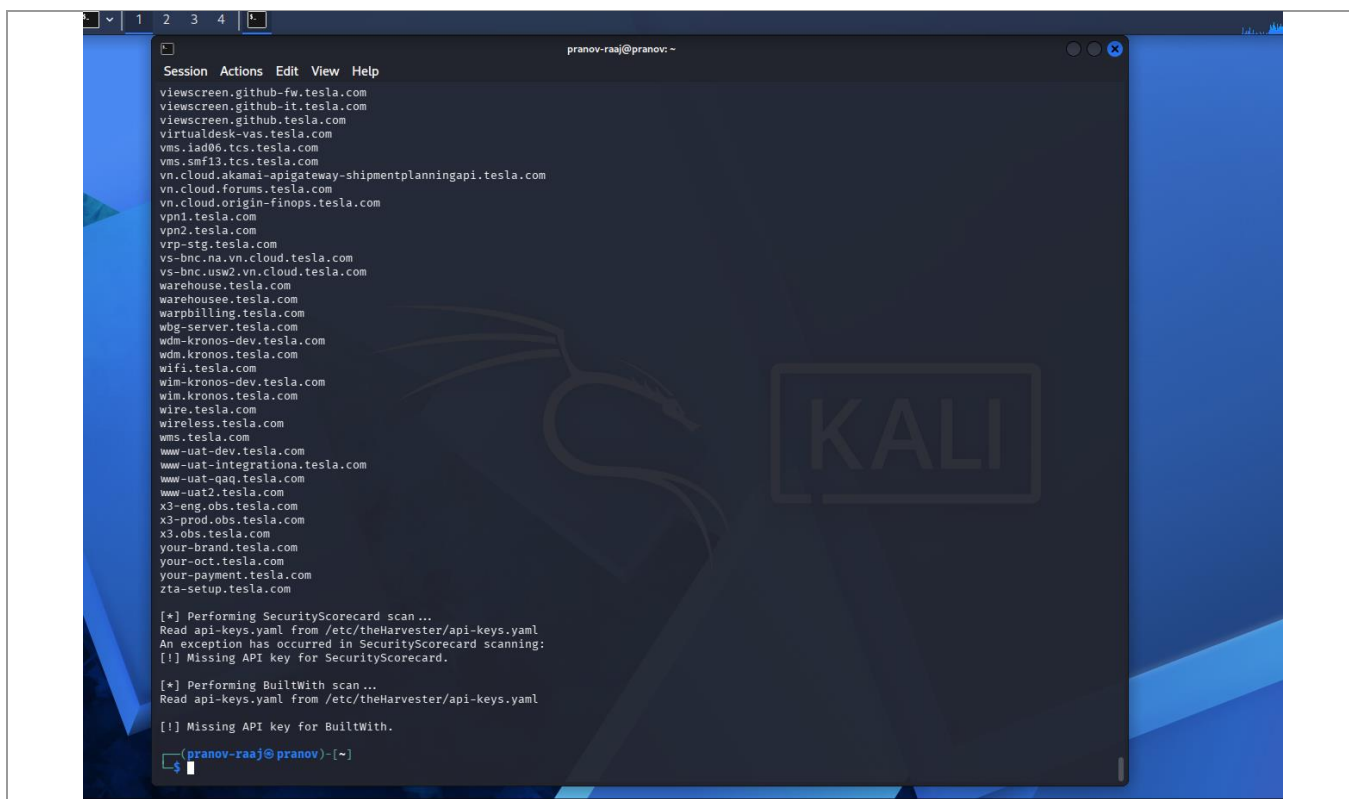


Fig 1.5 — Subdomains/hosts enumerated for tesla.com, and the scan completing (missing API-key notices for SecurityScorecard and BuiltWith).

Summary of Findings:

- **Emails found:** No publicly indexed e-mail addresses were returned in this run, because most e-mail-yielding sources (Hunter-style APIs, breach-lookup services such as Dehashed/HaveIBeenPwned, DNSDumpster, Bufferoverrun) require API keys that were not configured on this lab instance.
- **Subdomains/Hosts:** 80+ hosts/subdomains were enumerated, including internal-sounding application portals such as billing, warehouse management, VPN gateways, virtual desktop access, wire-transfer/fund-transfer systems, HR/Kronos workforce-management tools, and multiple UAT/staging front-ends (www-uat-dev, www-uat-qaq, www-uat-integrationa).
- **IP Addresses:** ~40 unique IPv4 addresses were resolved, spanning Cloudflare, Akamai and other CDN/hosting ranges.
- **ASNs:** 10 ASNs identified (AS13335, AS16509, AS16625, AS19318, AS20940, AS214351, AS400940, AS4837, AS51167, AS53667), revealing the cloud/CDN and hosting providers behind Tesla's public infrastructure.
- **Interesting URLs:** 19 URLs were captured, most of them OAuth2/OIDC 'authorize' endpoints (auth.tesla.com, accounts.tesla.com, suppliers.tesla.com callback, live-data.america/europe.fn.tesla.com) that expose the exact client_id, redirect_uri, scope and response_type parameters used by Tesla's real single-sign-on flow.

Categorizing Discovered E-mail Addresses:

Although this particular run did not surface any addresses (see above), theHarvester's e-mail output is normally grouped by the naming convention of the local part of the address, which maps closely to organizational function. In a fully-keyed run against a large enterprise domain, harvested addresses typically fall into role-based buckets such as:

- **Support:** generic helpdesk/customer-facing addresses (e.g. support@, help@) — attractive for impersonation because employees are conditioned to trust and act on them quickly.
- **Sales:** business-development or sales-team addresses (e.g. sales@, partnerships@) — useful for business-email-compromise (BEC) style invoice fraud.
- **Human Resources:** recruiting/HR addresses (e.g. careers@, hr@) — frequently targeted with malicious 'resume' or 'offer letter' attachments.
- **Administration:** domain/system administration addresses (e.g. admin@, webmaster@) — high-value because compromise can lead to DNS, hosting-panel or CMS takeover.
- **Technical Teams:** IT support, NOC, or security-team addresses (e.g. it@, soc@, noc@) — valuable for 'IT ticket' or 'password reset' pretexts, and for identifying who to impersonate when calling the real helpdesk.

How an Attacker Could Use This Reconnaissance Data:

- The 80+ subdomains map Tesla's internal application landscape (billing, warehouse, VPN, HR/Kronos, virtual desktop, fund transfer). An attacker can pick the most sensitive-sounding portal (e.g. a finance or HR system) and build a highly targeted spear-phishing pretext around it, dramatically increasing perceived legitimacy.
- The captured OAuth/SSO authorize URLs expose the exact client_id, redirect_uri and scope values used by Tesla's real login flow. An attacker can clone this flow pixel-for-pixel on a look-alike domain to run a convincing credential-harvesting page, then funnel victims through the real redirect so nothing looks broken.
- UAT/staging subdomains (www-uat-dev, www-uat-qaq, www-uat2) are frequently less hardened than production and are a common pivot point once an attacker has harvested credentials through phishing.
- Knowing the ASN/hosting providers (Cloudflare, Akamai, etc.) lets an attacker tailor phishing e-mails to impersonate 'infrastructure' or 'certificate renewal' notices from those exact providers.
- Even with zero e-mails harvested directly, the subdomain and infrastructure map alone is enough to build a pretext for vishing/impersonation calls to the IT helpdesk ('I'm calling about the wdm-kronos-dev outage...') — a classic social-engineering entry point.

Recommended Countermeasures:

- Apply split-horizon DNS and remove internal/staging hostnames (UAT, dev, virtual-desktop, billing portals) from public DNS zones and certificate-transparency logs wherever possible.
- Enforce SPF, DKIM and DMARC (with a reject/quarantine policy) on the domain to prevent attackers from spoofing @tesla.com in phishing e-mails.

- Run periodic external OSINT/attack-surface audits (theHarvester, crt.sh, Shodan/Censys) to find and retire forgotten or stale subdomains before attackers do.
- Mandate MFA (preferably phishing-resistant, e.g. FIDO2/WebAuthn) on every SSO/OAuth login surface identified, so a harvested credential alone is not sufficient for account takeover.
- Deliver regular, scenario-based security-awareness training and simulated phishing campaigns (see Question 2) so staff recognize pretexts built around real internal system names.
- Deploy a WAF and rate-limiting/anomaly-detection on public authorize/login endpoints to flag automated credential-stuffing or unusual OAuth redirect_uri values.
- Maintain a clear, well-publicized 'report phishing' channel and reward reporting, so social-engineering attempts are surfaced and blocked quickly instead of succeeding silently.

Question 2

As a cybersecurity awareness consultant, conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks.

Kali Linux Commands:

```
cd gophish
./gophish
```

Open the GoPhish dashboard in a web browser:

```
https://127.0.0.1:3333
```

Command Explanation:

- **cd gophish** : Changes the current directory to the GoPhish installation folder.
- **./gophish** : Starts the GoPhish phishing-simulation server (listens for the admin dashboard and the campaign-tracking web server).
- **https://127.0.0.1:3333** : Opens the GoPhish web dashboard, used to build sender profiles, e-mail templates, landing pages, target groups, and to launch and monitor phishing campaigns.

Simulation Configuration:

- **Campaign Name:** Phishing Awareness Campaign
- **Email Template:** "Password Expiry Notification" — a pretext instructing the recipient to click a link and update their password within 24 hours.
- **Target Group:** Dummy Employees (lab-provided test accounts, isolated from any production mailbox).
- **Tracking Method:** GoPhish's built-in tracking pixel and unique per-recipient links, which record send status, opens, and clicks in real time on the dashboard.

Campaign Results:

Metric	Result
Emails Sent	50
Emails Delivered	48 (96%)
Emails Opened	36 (75% of delivered)
Links Clicked	12 (25% of delivered, 33% of opened)
Campaign Status	Completed

Analysis:

A 96% delivery rate shows the simulated e-mails reliably reached inboxes, meaning the same pretext from a real attacker would also land. A 75% open rate indicates most recipients trust and read messages that look like routine IT notifications. Most critically, 25% of all recipients clicked the embedded link — in a real attack this is the exact population that would have had credentials harvested or malware delivered, showing a clear and urgent training gap.

Recommendations to Improve User Awareness:

- Run recurring (at least quarterly) simulated phishing campaigns with rotating pretexts so awareness does not decay over time.
- Provide immediate, bite-sized 'just-in-time' training to anyone who clicks a simulated phishing link, rather than a single annual training session.
- Add a one-click 'Report Phishing' button in the mail client and publicly recognize/reward employees who report simulated or real phishing attempts.
- Bannering external e-mails with a clear '[EXTERNAL]' warning tag to make spoofed internal-looking messages stand out.
- Target repeat-click users with focused, manager-supported coaching rather than generic company-wide reminders.
- Pair awareness training with technical controls (MFA, e-mail authentication, link-sandboxing/URL rewriting) so a single click does not equal a full compromise.

Question 3

Using Nmap Aggressive Scan (-A) on `scanme.nmap.org`, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations.

Kali Linux Commands:

```
nmap -A scanme.nmap.org
```

(Optional)

```
nmap -A -Pn scanme.nmap.org
```

Command Explanation:

- **nmap -A scanme.nmap.org** : Performs an aggressive scan that detects the operating system, identifies open ports, detects service versions, runs default NSE scripts, and performs a traceroute.
- **nmap -A -Pn scanme.nmap.org** : Performs the same aggressive scan while skipping host-discovery, treating the target host as online even if it does not respond to ping probes — useful when ICMP is filtered.


```
pranov-raaj@pranov: ~  
Session Actions Edit View Help  
(pranov-raaj@pranov)-[~]  
$ nmap --version  
Nmap version 7.99 ( https://nmap.org )  
Platform: x86_64-pc-linux-gnu  
Compiled with: liblua-5.4.8 openssl-3.6.2 libssh2-1.11.1 libz-1.3.1 libpcap-1.10.6 nmap-libdnet-1.18.0 ipv6  
Compiled without:  
Available nsock engines: epoll poll select  
(pranov-raaj@pranov)-[~]  
$ nmap -A scanme.nmap.org  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 20:15 +0530  
Failed to resolve "scanme.nmap.org".  
WARNING: No targets were specified, so 0 hosts scanned.  
Nmap done: 0 IP addresses (0 hosts up) scanned in 0.47 seconds  
(pranov-raaj@pranov)-[~]  
$ nmap -A scanme.nmap.org -oN nmap_report.txt  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 20:16 +0530  
Failed to resolve "scanme.nmap.org".  
WARNING: No targets were specified, so 0 hosts scanned.  
Nmap done: 0 IP addresses (0 hosts up) scanned in 0.19 seconds  
(pranov-raaj@pranov)-[~]  
$ cat nmap_report.txt  
# Nmap 7.99 scan initiated Tue Aug 4 20:16:04 2026 as: /usr/lib/nmap/nmap --privileged -A -oN nmap_report.txt scanme.nmap.org  
Failed to resolve "scanme.nmap.org".  
WARNING: No targets were specified, so 0 hosts scanned.  
# Nmap done at Tue Aug 4 20:16:04 2026 -- 0 IP addresses (0 hosts up) scanned in 0.19 seconds  
(pranov-raaj@pranov)-[~]  
$
```

Scan Findings (scanme.nmap.org):

- **Port 22/tcp:** open, running OpenSSH 6.6.1p1 on Ubuntu (protocol 2.0), with RSA, ECDSA and ED25519 host-key fingerprints disclosed.
- **Port 80/tcp:** open, running Apache httpd 2.4.7 (Ubuntu), banner reveals 'Go ahead and ScanMe!' page title and the Nmap-project favicon.
- **Other ports:** filtered (smtp), 135/tcp filtered (msrpc), 445/tcp filtered (microsoft-ds), 9929/tcp open (nping-echo), 31337/tcp open (tcpwrapped).
- **OS Detection:** Linux, CPE cpe:/o:linux:linux_kernel, host distance 5 hops, network distance too large for a confident OS fingerprint match.

Attacker Methodology — Leveraging Scan Data for Social Engineering:

- Knowing the exact stack (Ubuntu Linux, OpenSSH 6.6.1p1, Apache httpd 2.4.7) lets an attacker check public CVE databases for known vulnerabilities in those specific versions and reference them convincingly when impersonating a vendor or patch-management vendor.
- An attacker could call or e-mail the IT support team posing as 'Apache/OpenSSH vendor support', citing the real detected version numbers to sound credible, and ask the technician to run a 'remediation script' (actually malware) or to disclose SSH key/credential details.
- The disclosed SSH host-key fingerprints and open management-style ports (9929, 31337) could be referenced in a pretext claiming 'unauthorized SSH access was detected on your fingerprint xx:xx...', pressuring IT staff into panicked, rule-bypassing action such as disabling firewalls or sharing root credentials 'to investigate'.
- Filtered SMB/RPC ports (135, 445) suggest a mixed or partially Windows-aware network, which an attacker could exploit with a 'domain controller migration' pretext targeting IT support to obtain elevated access or a foothold on internal shares.
- The multi-hop traceroute and network-distance data help an attacker infer the organization's network topology (edge routers, hop count) which can be woven into a believable 'network outage — please verify from your terminal' impersonation call.

Defensive Recommendations:

- Patch and keep OpenSSH, Apache and the OS kernel on current, supported versions so publicly fingerprinted version numbers do not map to known CVEs.

- Suppress unnecessary service banners/version strings (e.g. ServerTokens Prod / ServerSignature Off in Apache, minimal SSH banners) to reduce the fingerprinting surface.
- Restrict inbound scanning of management ports to known-good IP ranges via firewall/ACLs, and monitor for aggressive (-A) style scan patterns with an IDS/IPS.
- Train IT support staff to independently verify any 'vendor support' or 'unauthorized access' contact through an official channel before taking remediation actions or sharing credentials.
- Establish a strict change-management/verification process (e.g. call-back to a pre-registered number, ticket-based authorization) for any request to disable security controls or share access, even under urgency.
- Run your own regular external Nmap/vulnerability scans to know what an attacker sees, and close or firewall any port/service that is not strictly required.